



密码协议

第三次作业讲解

2026年6月7日

第三次作业

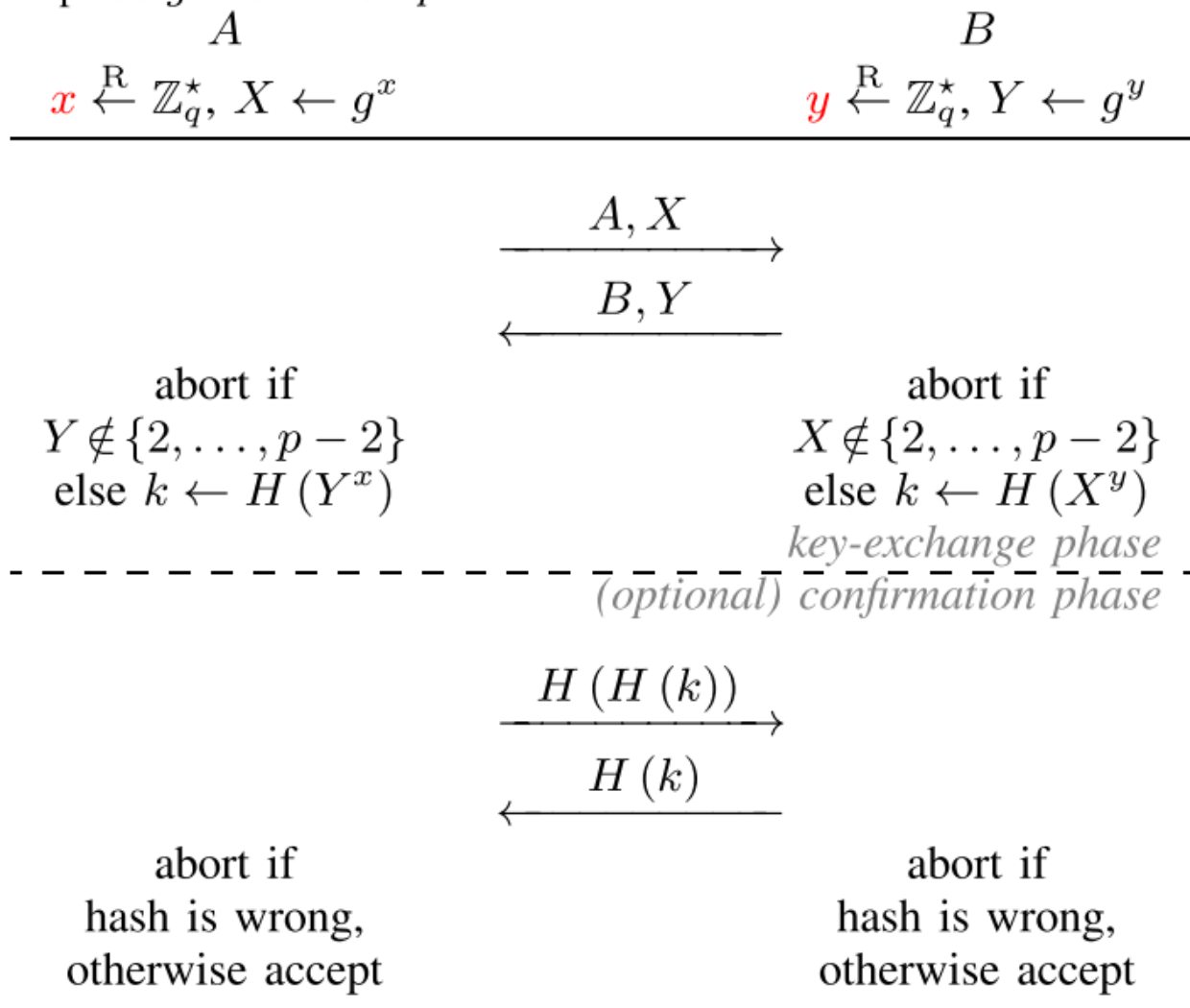
1. SPEKE 协议使用安全素数 $p = 2q + 1$ ，用口令派生出群生成元 $g = s^2 \bmod p$ ，平方的目的是什么？SPEKE 协议认证阶段中的两条消息能否调换顺序，为什么？为什么说针对 SPEKE 的平行会话攻击不是一个彻底成功的攻击？
2. 下图展示了一种将 SRP 协议通信轮数压缩至三轮的优化尝试。请分析该方案的安全缺陷，阐述具体的攻击原理，并给出完整的攻击流程图。

$$\begin{array}{lll} C \Rightarrow S & I, A & M_1 = H(A, B, S) \\ C \Leftarrow S & s, B, M_1 & \\ C \Rightarrow S & M_2 & M_2 = H(A, M_1, S) \end{array}$$

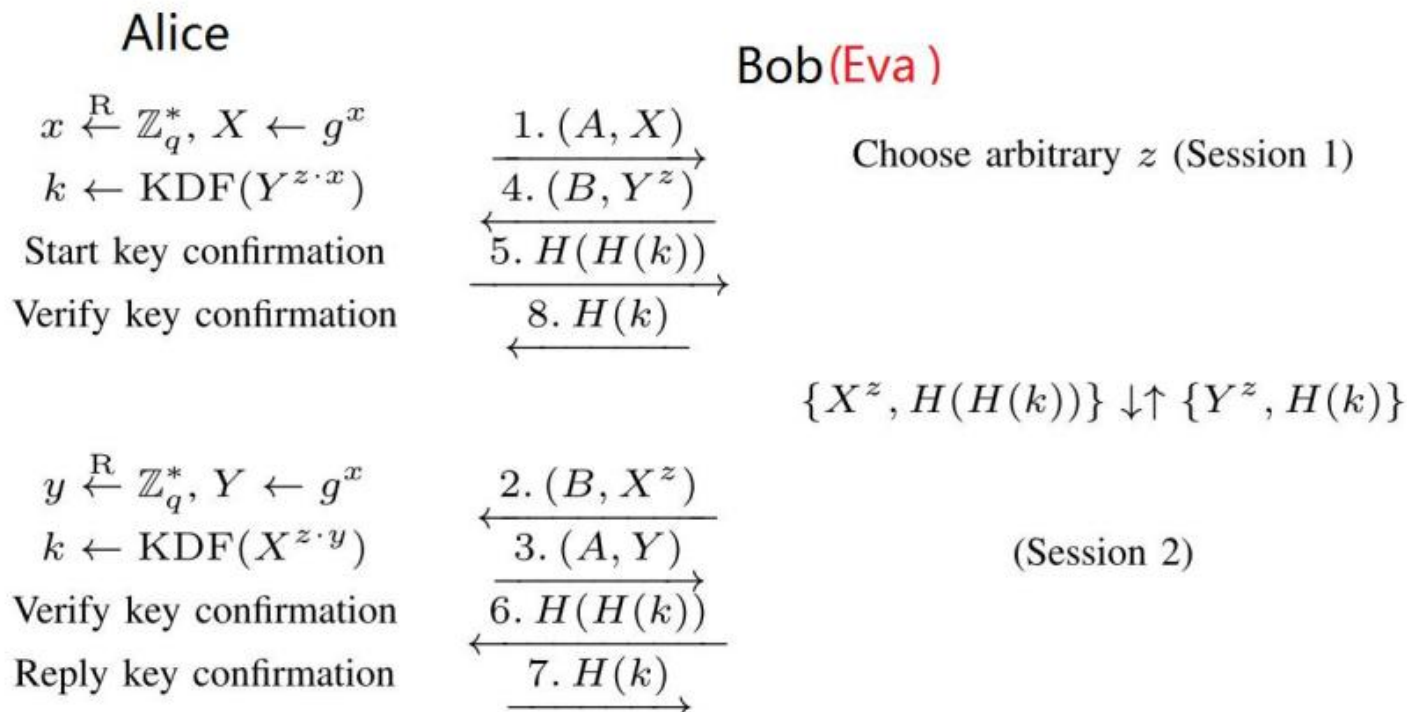
3. RSA-GPAKE 协议容易受到分离攻击。协议中的什么信息能够被攻击者利用进行分离攻击？如果攻击者发送的 $n_A = 5p$ ，一次能排除大约多少的口令？对于大小为 10^6 的口令字典，平均需要多少次成功测试会话能够确定出唯一的口令？应该如何改进协议以防止分离攻击？

1. 确保生成元 g 位于素数阶为 q 的子群中, $g^q = s^{2q} = s^{\varphi(p)} = 1 \bmod p$ 。前提是 g 不等于 1 或者 $p - 1$ 。
2. 检查 $X \notin \{2, \dots, p-2\}, Y \notin \{2, \dots, p-2\}$; 因为 p 是安全素数, 只有一个阶为 2 的小子群 $\{1, p-1\}$, 检查成本很低。
3. 不能调换顺序, 否则 $H(H(k))$ 可以根据 $H(k)$ 哈希得到, 无法确保参与方了解 k 。

Figure 1. Original SPEKE scheme. A and B share the password s and computed $g = s^2 \bmod p$.



针对SPEKE的攻击：平行会话攻击



- 平行会话攻击：Eva仿冒Bob, 同时与Alice进行两个会话
- 问题：该攻击是一个彻底成功的攻击吗？

不完美的攻击：敌手只能通过认证，但不能获得会话密钥

第三次作业

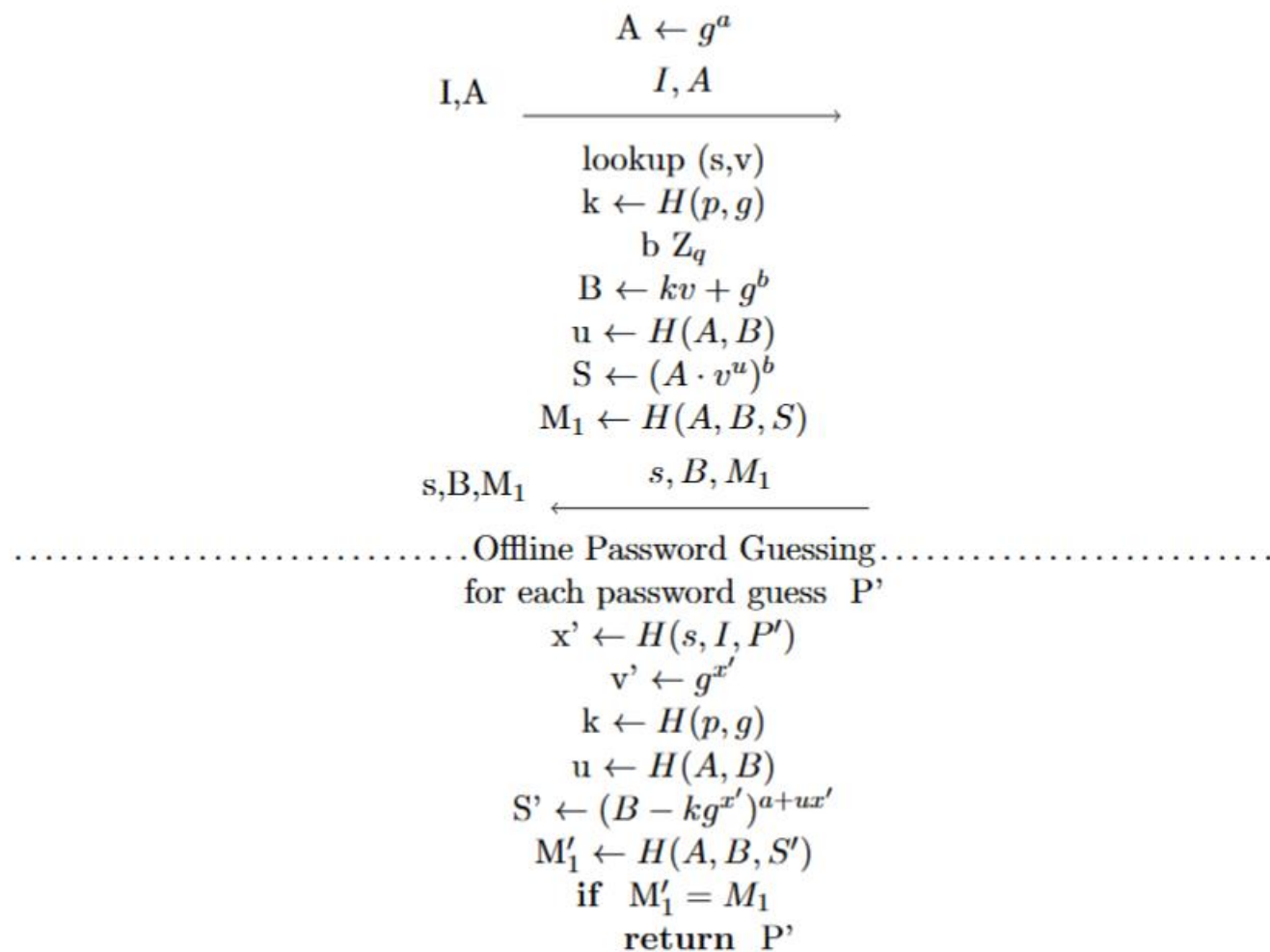
1. SPEKE 协议使用安全素数 $p = 2q + 1$ ，用口令派生出群生成元 $g = s^2 \bmod p$ ，平方的目的是什么？SPEKE 协议认证阶段中的两条消息能否调换顺序，为什么？为什么说针对 SPEKE 的平行会话攻击不是一个彻底成功的攻击？
2. 下图展示了一种将 SRP 协议通信轮数压缩至三轮的优化尝试。请分析该方案的安全缺陷，阐述具体的攻击原理，并给出完整的攻击流程图。

$$\begin{array}{lll} C \Rightarrow S & I, A & M_1 = H(A, B, S) \\ C \Leftarrow S & s, B, M_1 & \\ C \Rightarrow S & M_2 & M_2 = H(A, M_1, S) \end{array}$$

3. RSA-GPAKE 协议容易受到分离攻击。协议中的什么信息能够被攻击者利用进行分离攻击？如果攻击者发送的 $n_A = 5p$ ，一次能排除大约多少的口令？对于大小为 10^6 的口令字典，平均需要多少次成功测试会话能够确定出唯一的口令？应该如何改进协议以防止分离攻击？

服务器把认证证明 M_1 提前发送给客户端，而此时客户端尚未证明自己知道口令。

因此攻击者可以把服务器当成一个“口令验证预言机 (password oracle)”，从而进行离线字典攻击。



第三次作业

1. SPEKE 协议使用安全素数 $p = 2q + 1$ ，用口令派生出群生成元 $g = s^2 \bmod p$ ，平方的目的是什么？SPEKE 协议认证阶段中的两条消息能否调换顺序，为什么？为什么说针对 SPEKE 的平行会话攻击不是一个彻底成功的攻击？
2. 下图展示了一种将 SRP 协议通信轮数压缩至三轮的优化尝试。请分析该方案的安全缺陷，阐述具体的攻击原理，并给出完整的攻击流程图。

$$\begin{array}{lll} C \Rightarrow S & I, A & M_1 = H(A, B, S) \\ C \Leftarrow S & s, B, M_1 & \\ C \Rightarrow S & M_2 & M_2 = H(A, M_1, S) \end{array}$$

3. RSA-GPAKE 协议容易受到分离攻击。协议中的什么信息能够被攻击者利用进行分离攻击？如果攻击者发送的 $n_A = 5p$ ，一次能排除大约多少的口令？对于大小为 10^6 的口令字典，平均需要多少次成功测试会话能够确定出唯一的口令？应该如何改进协议以防止分离攻击？

RSA-GPAKE协议的分离攻击基本思想

□ 本质：利用服务器不自觉提供的互素差别Oracle服务！

(1) 假冒合法用户与Server进行一次主动会话，从Server的返回信息里找到口令相关信息：

$$\gcd(\alpha^*, n_A) \stackrel{?}{=} 1$$

(2) 进行本地猜测，从 $\mathcal{D}_{pw}$ 中排除掉 $\frac{1}{5} \cdot \mathcal{D}_{pw}$ 与返回信息不符合的口令；

由 $n_A = 5p$ 可得

$$\begin{aligned}\Pr[\mathbf{E}] &= \Pr[(\alpha^* \bmod 5 = 0) \vee (\alpha^* \bmod p = 0)] \\ &= \frac{1}{5} + \frac{1}{p} - \frac{1}{5p} = \frac{1}{5} + \frac{4}{5p} \approx \frac{1}{5}\end{aligned}$$

(3) 回到 (1)，直到 $\mathcal{D}_{pw}$ 中剩下1个口令，

攻击者平均需要的成功测试会话次数：

用户口令空间 $\mathcal{D}$ 通常十分有限，如 $|\mathcal{D}|=10^6$ 。

由 $(\frac{4}{5})^l \cdot |\mathcal{D}| = (\frac{4}{5})^l \cdot 10^6 = 1$ 可计算

$$l = \log_{\frac{5}{4}} |\mathcal{D}| = \log_{\frac{5}{4}} 10^6 \approx 61.91$$

$\xrightarrow{C, n, e, n', e', r_1}$ e 为奇素数?
 n 为奇数且强度足够?
 若 e 和 n 通过检测, $m = \lfloor \log_e^n \rfloor$
 $a_1 \in_R Z_n^*, r_2 \in_R \{0, 1\}^k$
 设 $ID_1 = C \| G \| n \| e \| n' \| e'$
 $\alpha = H(pw \| r_1 \| r_2 \| ID_1)$
 $\xleftarrow{r_2, z}$ 若 $\gcd(\alpha, n) \neq 1$, 则拒绝
 $z = E^m(aE(a_1))$

改进：将直接拒绝改为依然返回随机数



$\xrightarrow{C, n, e, n', e', r_1}$ e 为奇素数?
 n 为奇数且强度足够?
 若 e 和 n 通过检测, $m = \lfloor \log_e^n \rfloor$
 $a_1 \in_R Z_n^*, r_2 \in_R \{0, 1\}^k$
 设 $ID_1 = C \| G \| n \| e \| n' \| e'$
 $\alpha = H(pw \| r_1 \| r_2 \| ID_1)$
 $\xleftarrow{r_2, z}$ 若 $\gcd(\alpha, n) \neq 1$, 令 $\alpha \in_R Z_n^*$
 $z = E^m(aE(a_1))$